

Pavo Cloud

Autonomous prior authorization over an agent-to-agent protocol

Dhanvanth Lakshman, CFO · Viraj Gadeela, CTO · Harry Wang, CEO | AI for Business Track | September 2026

88.6ms MEDIAN DECISION, END-TO-END	138 TESTS PASSING, 0 FAILING	19,541 LINES COMMITTED, 4 PHASES	100% DECISIONS CARRYING A RULE ID
---	--	--	--

1 Where we are

Round 1 argued that prior authorization is slow because a person has to start every request. Round 2 is the working system: all four build phases complete and running — the autonomous authorization loop, consumer price transparency, cryptographic identity with autonomous appeals, and zero-knowledge proofs over patient criteria.

Every number in this report was measured on the committed code on 13 September 2026, not estimated. The commands that reproduce them are listed in §6.3.

The core claim from Round 1 — that a routine authorization can be decided without a human touching a form — now has a number attached. A complete request, from simulated EHR webhook through FHIR assembly, RSA signing, signature verification, rule evaluation and a five-entry audit trail, resolves in a median of **88.6 ms**. The industry baseline is 3–14 days.

2 What changed since Round 1

AREA	ROUND 1 POSITION	ROUND 2 POSITION, AND WHY IT MOVED
Decision speed	"Under 5 minutes"	Measured at 88.6 ms median for the agent loop. The five-minute figure now covers the round trip <i>including</i> EHR write-back and payer network latency; the agent work is sub-second.
AI architecture	"Deterministic layer + predictive layer"	Built, and the split is stricter than described. No language model touches an authorization decision. The probabilistic layer is confined to document parsing, CPT mapping, and appeal drafting — each thresholded, each escalating below threshold.
Privacy	"Minimum necessary, encrypted"	Stronger. Patient identifiers are SHA-256 hashed before storage, and a Groth16 circuit proves three coverage criteria without transmitting age, diagnosis or deductible at all.
Financials	Break-even to 87% margin; \$1.0M → \$8.2M → \$36.1M	Revenue targets held, but rebuilt bottom-up from customer counts and measured infrastructure cost rather than asserted. Year 1 gross margin is 31% — pilots are delivered near cost — reaching 87% by Year 3. The Year 1 figure was optimistic and is corrected here.

3 The four things that are true in code, not just on paper

1 · EVERY DECISION NAMES ITS RULE

The rule engine cannot return an outcome without a `rule_id`. That ID is written to `audit_log` on every decision and returned in the API response. There is no code path that produces an unexplained outcome. **6 TESTS**

2 · AMBIGUITY ESCALATES BY DEFAULT

The rule set ends in a catch-all, `PAV0-R005`, whose outcome is `ESCALATED`. Anything the system does not have a definitive rule for routes to a human with the record already assembled. Escalation is the fallback, not an exception path. **VERIFIED LIVE**

3 · AN UNVERIFIED MESSAGE NEVER ACTS

Signature verification runs before the payload is read. A tampered or unsigned envelope is rejected with HTTP 401, the rejection is audited, and the rule engine is never reached. **4 TESTS**

4 · NO AUTOMATED FINAL DENIAL

A denial is either appealed or escalated. When the payer agent rejects an appeal it returns `ESCALATED` under `PAV0-A002` — never `DENIED`. A machine cannot issue a final no to a patient in this system. **2 TESTS**

4 System Architecture 2.0 — the authorization pipeline

One order, end to end. Solid arrows carry data; the dashed arrow is the only path a human sits on. Timings are measured medians.



4.1 Why the boundary at step 4 matters

Verification is the first thing the payer agent does, and it happens *before* the payload is deserialised into anything the rule engine can see. This is not a validation step running alongside processing — it is a gate. Provenance is established, or nothing happens. A judge testing this can tamper with any signed field and watch the request die with a 401 and an `aria verification.failed` audit row.

4.2 Where inference is allowed, and where it is forbidden

Round 1 described a deterministic layer and a predictive layer. The built system draws the line harder than that. The rule is enforced by the shape of the code: **a language model never renders an authorization decision.**

LAYER	WHAT IT DOES	WHERE IT RUNS	GUARANTEE
Deterministic DECIDES	Identity verification, coverage rules, ZK verification, pricing arithmetic, denial classification.	<code>rules.py</code> , <code>aria.py</code> , <code>crypto.py</code> , <code>zk/prover.py</code> , <code>classifier.py</code>	Same input always yields the same output. Every outcome traces to a named rule ID. Confidence is 1.0 because the match is definitive, not because a model is sure.
Probabilistic ASSISTS	Insurance-card and EOC parsing, plain-language → CPT mapping, appeal letter drafting.	<code>insure/parser.py</code> , <code>insure/cpt.py</code> , <code>appeals/letter.py</code>	Output is scored and thresholded. Below threshold it escalates. It is never the last word on whether a patient gets care.

The consequence, stated plainly

If our model provider went down tomorrow, prior authorization would keep working — the core loop has no inference in it. That is also why the marginal cost of an authorization is a fraction of a cent (\$9.3): there is no token spend on the critical path.

5 Architecture 2.0, continued — the sub-pipelines

5.1 Appeals sub-pipeline

Triggered only by a **DENIED** outcome. Two hard stops sit ahead of anything a model produces.

```
DENIED
├─ classify_denial(reason_code)
│   exact X12 CARC match → keyword → "other"
│   └─ not_covered → ESCALATE, no letter
│       Coverage is a contract question,
│       not a clinical one. HARD STOP.
├─ medical_necessity | missing_info | other
│   PubMed E-utilities → top 3 abstracts
│   │   unreachable → 0 citations, flow
│   │   continues and reports the failure
│   Claude drafts letter + PMID cites
│   │   → confidence score
│   │   ≥ 0.70 → sign ARIA APPEAL → payer
│   │   │   payer > 0.85 → APPROVED PAV0-A001
│   │   │   payer ≤ 0.85 → ESCALATED PAV0-A002
│   │   │   never DENIED
│   │   < 0.70 → ESCALATE with reviewer
│   │   notes pre-populated: procedure,
│   │   diagnosis, category, confidence,
│   │   every citation retrieved
```

Classification is deterministic on purpose: the whole path forks on that one call, so it reads exact X12 CARC codes first (50 , 96 , 16 , 204 , 252) before falling back to ordered keyword groups. An unrecognised reason becomes **other** , which still gets an appeal.

5.3 Zero-knowledge proofs over patient criteria

A 68-line circom circuit compiled to Groth16 over BN254, proving three things while transmitting none of the data behind them: the patient meets the age floor, the diagnosis matches the covered condition, the deductible requirement is satisfied. A live proof returns six public signals — three verdicts, three policy parameters — and nothing else. A dedicated test asserts the private inputs never appear in the response body.

Stated limitation, because a judge will ask. The approved-diagnosis check compares against a single hash, so a passing proof does tell the payer the patient carries that one diagnosis. Proving membership in a set of many codes without revealing which requires a Merkle circuit and is out of scope for the prototype. The age and deductible criteria leak nothing. Separately, `zk/build.sh` runs its own local Powers of Tau ceremony, so whoever builds the artifacts knows the toxic waste — fine for a prototype, never for production.

5.4 The coverage rule set

Evaluated in order, first match wins — so the specific knee rule is checked before the general one. Precedence is a property of the list, and it is tested. `GET /api/rules` returns this table at runtime, which is how the dashboard explains a decision back to a user.

RULE	PROCEDURE	DIAGNOSIS	OUTCOME
PAV0-R001	70553 MRI brain	any	APPROVED
PAV0-R002	27447 knee replacement	M17.11	APPROVED
PAV0-R003	27447 knee replacement	any other	ESCALATED
PAV0-R004	99214 office visit	any	APPROVED
PAV0-R005	anything else	any	ESCALATED

Five rules prove the mechanism, not a market. Scaling the list is costed as the largest COGS line in §9.3.

5.2 Insure sub-pipeline (price transparency)

The consumer layer — where the probabilistic layer does most of its work, and where every output is labelled by source.

```
card.jpg + eoc.pdf
├─ member ID → SHA-256 → storage path
│   uses the hash, never the raw ID
├─ Claude vision (card) └─
├─ Claude document (EOC) └─ insurance_plan
├─ plain language → Claude → CPT code
│   cpt_source: "claudio" | "sample"
├─ 5 facility quotes, deterministic from CPT
├─ estimate_member_cost() per facility
│   not met: min(cash, coins × negotiated)
│   met: coins × negotiated
├─ rank by what the member actually pays
│   → audit_log, entity_type='price_query'
```

LIVE OUTPUT, KNEE REPLACEMENT, 20% COINSURANCE

FACILITY	NEGOTIATED	CASH	YOU PAY
Northgate Community	\$26,482	\$7,176	\$5,296
Parkside Diagnostic	\$29,887	\$11,051	\$5,977
Riverside Imaging	\$31,394	\$11,444	\$6,279
Clearview Ambulatory	\$34,397	\$7,275	\$6,879
Metro Valley Medical	\$38,857	\$12,608	\$7,771

From `POST /api/insure/query`, 13 Sep 2026. Every row ships a *breakdown* object showing the arithmetic. Spread between best and worst: **\$2,475 for the same procedure.**

5.5 What a signed ARIA envelope looks like

The seven fields above the signature are the ones it covers; change any byte and verification fails.

```
{ "aria_version": "1.0",
  "message_id": "2531910f-3984-4a82-94d9-efa08...",
  "timestamp": "2026-09-13T12:37:07.533216Z",
  "sender": { "agent_id": "agent://pavo/provider/...",
    "npi": "1234567893", "verified": true },
  "receiver": { "agent_id": "agent://pavo/payer/...",
    "payer_id": "MER001" },
  "payload_type": "AUTH_REQUEST",
  "payload": { "procedure_code": "27447",
    "diagnosis_code": "M17.11",
    "patient_id": "pat_94cc12784b6586...",
    "fhir_bundle": { ... } },
  "signature": "<RSASSA-PSS over SHA-256 of the above>" }
```

Note *patient_id* — the hash is what travels, and it is the only patient identifier the payer ever receives.

6 The Build Log — proof of progress

Repository: `hwangus922/AI20-Pavo-Cloud` . Twelve commits across five merged pull requests — one per build phase, plus a hardening pass. Every figure below was produced by the commands in §6.3, run against the committed code.

5 MERGED PRS, 4 PHASES	19,541 LINES ADDED	138 TESTS, ALL PASSING	23 API ENDPOINTS	9 DATABASE TABLES
-------------------------------------	------------------------------	----------------------------------	----------------------------	-----------------------------

6.1 Commit history

PR	DATE	PHASE	DIFF	WHAT IT DELIVERED
#1	7 Sep	Phase 1 — core loop	+9,429 / 46 files	Provider and payer agents, ARIA v1.0 envelope, FHIR R4 assembly, five-rule engine, audit log, Next.js dashboard, Supabase schema.
#2	8 Sep	Phase 2 — Insure	+2,364 / 28 files	Document parsing, CPT mapping, facility quotes, the ranking algorithm and its cost breakdown, upload storage, consumer UI.
#3	9 Sep	Phase 3 — identity & appeals	+2,948 / 34 files	RSA-2048 provisioning and rotation, RSASSA-PSS signing and verification, denial classifier, PubMed retrieval, appeal drafting, the 0.70 threshold.
#4	9 Sep	Phase 4 — ZK & demo	+3,922 / 50 files	The circom circuit and compiled artifacts, snarkjs bridge, the six-step guided demo, the audit explorer with CSV export, live system statistics.
#5	10 Sep	Deployment hardening	+409 / 10 files	Three failures that only appear when deployed: key rotation across restarts, demo document loading, CORS handling.
Total across 12 commits			+19,541 / -367	170 file changes

6.2 Test suite — 138 passing, 0 failing

SUITE	FNS	COVERS
<code>test_rules.py</code>	6	All five rules, precedence, code normalisation, every decision carrying a rule ID
<code>test_flow.py</code>	19	Webhook end to end, FHIR assembly, raw PHI never stored, signature round trip, tamper rejection , private keys never persisted
<code>test_insure.py</code>	32	Upload validation, CPT mapping, both cost formulas, every ranking branch, sample-data labelling
<code>test_appeals.py</code>	29	Denial classification, PubMed parsing against fixtures, each appeal outcome, no automated final denial
<code>test_zk.py</code>	22	Real proofs, every criterion branch, tamper rejection, private inputs absent from responses , system stats
<code>test_persistence.py</code>	7	Supabase interface conformance, key rotation across two boots
115 functions	138	cases, 23.4 s

Function and case counts differ because several tests are parameterised — `test_five_hardcoded_rules` alone runs one case per rule.

6.3 Codebase and build

COMPONENT	LINES	STATUS
Backend — FastAPI, Python	6,799	138 TESTS PASS
Frontend — Next.js 14, TypeScript	3,703	BUILDS CLEAN
Database — SQL migrations	183	4 migrations, 9 tables
ZK — circom + snarkjs	180	artifacts committed

Frontend production build compiles clean — 7 routes, 8 static pages, 87.4 kB shared JS — and `tsc --noEmit` passes with zero errors. `/health` reports storage backend, file store, whether a model key is configured, and whether the ZK artifacts are present, so the operating mode is never ambiguous during a demo.

THE 30-SECOND DEMO

`/demo` runs all six steps from live data with no further input: EHR trigger, identity, zero-knowledge, rule engine, decision, price. Measured full run: **~11 seconds**. Each step also has a manual Next button, and a failed step shows a retry rather than a broken page.

REPRODUCE EVERY NUMBER ON THIS PAGE

```
git log --shortstat      # +19,541 / -367, 170 files
cd backend && .venv/bin/python -m pytest # 138 passed
cd frontend && npx tsc --noEmit && npm run build
curl -s localhost:8000/api/system/stats
# average_resolution_seconds: 0.0447
```

The ZK tests need `cd zk && npm install` first; without snarkjs those 7 fail on a missing dependency rather than a logic error, and `/health` reports `zk_artifacts_available` accordingly.

7 Risk Mitigation Protocol

The governing principle: **the safe outcome is the default, not the exception**. Every failure mode below resolves toward a human or toward a refusal to act — never toward a guess. Each row names the code path that enforces it and the test that proves it.

7.1 The escalation ladder

- 1

No definitive rule match → ESCALATED The rule set terminates in `PAV0-R005`, a catch-all whose outcome is `ESCALATED`. A request for a procedure with no coverage rule cannot fall through to an approval or a denial; there is no such path.
`VERIFIED LIVE: CPT 12345 → PAV0-R005`
- 2

Signature fails → 401, payload never read Verification precedes deserialisation. The rejection is written to `audit_log` as `aria.verification.failed` with the reason, and the rule engine is never invoked. Applies identically to authorization requests and appeals. `TEST_TAMPERED_ENVELOPE_FAILS_VERIFICATION`
- 3

Appeal confidence below 0.70 → human, with the work already done Nothing below threshold reaches a payer. The escalation carries pre-populated reviewer notes: procedure and diagnosis with descriptions, denial category, confidence score, and every citation retrieved. A reviewer opens a prepared file, not a blank one. `TEST_LOW_CONFIDENCE_ESCALATES_RATHER_THAN_SUBMITTING`
- 4

Coverage exclusion → never auto-appealed A `not_covered` denial is a contract question, not a clinical one. No letter drafted, no evidence gathered, no model called. Straight to a person. `TEST_NOT_COVERED_SKIPS_THE_APPEAL_AND_ESCALATES`
- 5

Appeal rejected → ESCALATED, never DENIED The payer agent answers an unsuccessful appeal with `PAV0-A002`, an escalation. No code path issues a final denial to a patient without a licensed human. `TEST_PAYER_ESCALATES_RATHER_THAN_FINALLY_DENYING`
- 6

Model unavailable → everything escalates; evidence source down → degrade, don't fall over Without model credentials the letter generator returns a labelled placeholder scored `0.0`, below threshold, so every appeal escalates — the degraded state is the safe state, and `/health` reports it rather than hiding it. When PubMed is blocked the appeal completes with zero citations and records the failure; confidence drops, which pushes it into human review. Failures propagate into caution, not into a worse letter.

7.2 Failure mode register

FAILURE	DETECTION	AUTOMATED RESPONSE	HUMAN SLA	OWNER
Ambiguous clinical case	No definitive rule match	Status set to <code>escalated</code> ; FHIR bundle, rule trace and audit trail attached	4 business hours	Payer clinical reviewer
Forged or replayed message	Signature verification	HTTP 401 before parsing; rejection audited with reason	Immediate alert	Pavo security on-call
Low-confidence appeal	Score < 0.70	Held; reviewer notes generated; never transmitted	1 business day	Provider appeals staff
Model provider outage	<code>claudio_configured</code> / API error	Labelled placeholder at confidence 0.0 → universal escalation. Core authorization loop unaffected.	None required	Pavo platform
Evidence source down	HTTP failure on E-utilities	Zero citations, failure recorded, confidence lowered	Follows appeal SLA	Provider appeals staff
Key rotation on restart	Verification failure against old key	Previous key revoked before new one registered; one active key per org enforced	None required	Pavo platform
Rule library drift	Quarterly criteria diff vs. payer-published policy	Affected rules flagged; requests matching them escalate until re-validated	5 business days	Pavo clinical informatics
Demographic skew in outcomes	Quarterly audit of approval rates across demography, geography, diagnosis	Rules driving a disparity are suspended to <code>ESCALATED</code> pending review	Quarterly cycle	Pavo clinical + compliance

Human-in-the-loop is a routing decision, not a review queue

Every escalation arrives complete. The reviewer receives the FHIR bundle, the rule that fired with its full description, the signature verification result, the denial category, the confidence score, and every citation retrieved — assembled before they open it. The bottleneck Round 1 identified was never clinical judgment; it was the paperwork wrapped around it. We removed the paperwork and left the judgment.

8 Risk, continued — privacy, and what is *not* yet mitigated

8.1 Privacy controls that hold in code

CONTROL	ENFORCEMENT
Raw PHI never stored	Patient identifiers SHA-256 hashed at the request boundary, before the first write. Verified by <code>test_raw_patient_id_is_never_stored</code> .
Member IDs hashed too	Including the ID read off an insurance card; the hash, not the raw value, forms the storage path.
Private keys never persisted	<code>org_keys</code> holds the public key and a SHA-256 digest of the private key. Nothing else. Verified by <code>test_private_keys_are_never_stored</code> .
Minimum necessary by construction	The ZK circuit lets a payer confirm eligibility criteria without receiving age, diagnosis code, or deductible amount at all.
Sample data always labelled	Without model credentials the parsers return obvious placeholders, and both the API response and the UI say so. Nothing silently invents a member's plan.
Immutable decision record	Five audit entries per authorization, each with before and after state. The decision row always carries its <code>rule_id</code> .

8.2 Honest gaps, and the plan for each

These are prototype limitations we would rather state than be asked about.

GAP	PLAN
ZK diagnosis check is single-hash DESIGN LIMIT	A passing proof reveals which covered diagnosis the patient carries. Needs a Merkle set-membership circuit. Scoped for the next phase.
Trusted setup is local NOT PRODUCTION SAFE	<code>build.sh</code> runs its own Powers of Tau, so the builder knows the toxic waste. Production requires a multi-party ceremony.
NPI verification is a flag STUBBED	Currently set from the seeded organisation record. Needs a live NPES/CMS enrollment lookup with a cached mirror. One integration.
Facility pricing is mocked STUBBED	Deterministic from the CPT code, not gathered. Replaced by the Vapi voice agent plus payer machine-readable transparency files.
Five rules, not a rule library SCOPE	Enough to prove the mechanism, not a market. The commercial build is clinical informaticists encoding each payer's published criteria — costed as a named COGS line in §9.
Predictive classifier not built DELIBERATE	The threshold and its config key exist; the model does not. Until it does, non-definitive cases escalate. That is the correct default and we are in no hurry to change it.
Federated learning not built DELIBERATE	Round 1 roadmap item. Not started, and not on the critical path to revenue.

8.3 The one that matters most: pricing formulas we implemented but do not endorse

The Phase 2 specification defines member cost as `min(cash, coinsurance × negotiated)` before the deductible is met and `coinsurance × negotiated` after. We implemented that verbatim, and it is **not how a real plan behaves** — before the deductible is met a member normally owes the full negotiated rate, with coinsurance beginning afterwards. One visible consequence: at a typical 20% coinsurance the insurance path always beats cash, so the cash-is-cheaper case, which is the product's central insight, only surfaces at higher coinsurance.

We are flagging this rather than quietly fixing it because it illustrates the discipline we want judged: the specification and the implementation agree, the divergence from reality is documented, and there is exactly one function to change — `estimate_member_cost` in `insure/ranking.py`. Changing it is a product decision, and we would rather make it with a payer in the room than guess.

8.4 Regulatory and ethical posture

OVERREACH

Pavo never judges medical appropriateness. The rule engine matches published criteria; it does not form a clinical opinion. Every denial reaches a licensed human. Structurally enforced, not policy-enforced.

BIAS

Approval rates audited quarterly across demography, geography and diagnosis. Because every decision carries a rule ID, a disparity is traceable to the specific rule producing it — and that rule can be suspended to `ESCALATED` in one change.

PROVENANCE

Cross-organisation messages are signed and verified against registered public keys. A payer can prove which provider sent a request and that nothing was altered in transit. This is what makes an agent-to-agent network auditable.

9 Three-Year Financial Model

Built bottom-up from customer counts and measured infrastructure cost. The full workbook — seven tabs, every formula live — accompanies this report as `Pavo_Cloud_3Yr_Financial_Model.xlsx`. Every input on this page is a driver in that file.

9.1 Volume drivers

DRIVER	2026	2027	2028	BASIS
Provider groups — ending	110	560	2,240	Sales plan
Provider groups — average active	55	330	1,400	Monthly weighted
Physicians per group	8	8	8	Mid-market target
Prior auths per physician per week	30	30	30	Conservative vs. AMA's 43–45
Share routed through Pavo	25%	40%	50%	Grows with rule coverage
Authorizations per group per year	3,120	4,992	6,240	Calculated
Total authorizations processed	171,600	1,647,360	8,736,000	
Payer contracts — average active	11	84	160	About 18% of the ~900 CMS-0057-F payers by 2028

9.2 Revenue build

STREAM	2026	2027	2028	PRICE
Per-authorization fees	\$514,800	\$4,942,080	\$26,208,000	\$3.00 / auth
Provider subscriptions	\$264,000	\$1,584,000	\$6,720,000	\$400 / mo
Payer compliance API	\$220,000	\$1,680,000	\$3,200,000	\$20,000 / yr
Total revenue	\$998,800	\$8,206,080	\$36,128,000	+722% / +340%

This reconciles to the \$1.0M / \$8.2M / \$36.1M presented in Round 1 — but those figures were asserted, and these are derived. The \$3.00 authorization fee remains 85–92% below the \$15–\$40 payers spend manually today.

9.3 Cost of revenue — where the money actually goes

LINE	2026	2027	2028	DRIVER
Cloud infrastructure — compute, DB, storage, egress	\$54,000	\$198,000	\$900,000	Volume + 7-yr retention
Model API — Insure parsing, appeal drafting	\$11,000	\$62,000	\$280,000	Not on the auth path
Clinical rule library — informaticists	\$189,000	\$455,000	\$1,080,000	1.5 → 3.5 → 8.0 FTE
Implementation & onboarding	\$224,000	\$476,000	\$1,428,000	2.0 → 4.0 → 12.0 FTE
Customer support	\$92,000	\$190,000	\$784,000	1.0 → 2.0 → 8.0 FTE
Security & compliance — SOC 2, pen test, HIPAA/BAA	\$118,000	\$112,000	\$290,000	Type II in Yr 1
Total cost of revenue	\$688,000	\$1,493,000	\$4,762,000	
Gross profit / gross margin	\$310,800 · 31%	\$6,713,080 · 82%	\$31,366,000 · 87%	

The number a judge should push on: marginal cost per authorization

Measured, not assumed. One authorization is ~89 ms of a single vCPU, eight database rows totalling roughly 6 kB, and **zero model tokens** — the deterministic core has no inference in it. Marginal infrastructure cost lands near **\$0.00057 per authorization** against a \$3.00 fee. The real cost of this business is not servers; it is the clinical informaticists encoding each payer's criteria into deterministic rules. That is the largest COGS line in every year, and it is why gross margin climbs with volume rather than with technology.

10 Unit economics, P&L, and the ask

10.1 CAC, LTV, and payback

METRIC, AT 2028 ECONOMICS	PROVIDER GROUP	PAYER	BLENDED
Annual revenue per account	\$23,520	\$20,000	\$23,159
Gross profit per account (86.8%)	\$20,420	\$17,364	\$20,106
Annual logo churn	5%	2%	4.7%
CAC	\$6,000	\$22,000	\$6,699
LTV, 3-year	\$58,248	\$51,057	\$57,533
LTV, 5-year	\$92,387	\$83,415	\$91,530
LTV : CAC (3-year)	9.7×	2.3×	8.6×
CAC payback	3.5 mo	15.2 mo	4.0 mo

CAC falls from \$9,500 (2026) to \$6,000 (2028) for provider groups and \$34,000 to \$22,000 for payers. LTV is stated on a 3-year horizon deliberately; the 5-year figure is shown for comparison but we do not underwrite on it.

Read the payer column correctly. At 2.3× LTV:CAC and a 15-month payback, payer contracts do not pay for themselves as a standalone product — and we are not pretending otherwise. **The payer contract is a distribution channel, not a profit centre.** Signing one payer makes Pavo reachable by every provider group already submitting authorizations to it, which is precisely why provider CAC falls 37% across the plan. Judged on its own the payer line looks weak; judged as the thing that makes the provider line work, it is the highest-leverage spend in the model.

10.2 Three-year P&L

	2026	2027	2028
Revenue	\$998,800	\$8,206,080	\$36,128,000
Cost of revenue	(\$688,000)	(\$1,493,000)	(\$4,762,000)
Gross profit	\$310,800	\$6,713,080	\$31,366,000
Gross margin	31%	82%	87%
Research & development	(\$680,000)	(\$2,100,000)	(\$4,680,000)
Engineers	4	12	26
Sales & marketing	(\$1,657,000)	(\$6,678,000)	(\$12,260,000)
New logos acquired	128	592	1,830
General & administrative	(\$340,000)	(\$1,150,000)	(\$3,200,000)
Total operating expense	(\$2,677,000)	(\$9,928,000)	(\$20,140,000)
EBITDA	(\$2,366,200)	(\$3,214,920)	\$11,226,000
EBITDA margin	(237%)	(39%)	31%

Peak cumulative burn: \$5.58M, reached in Q4 2027. The company turns EBITDA-positive during 2028.

10.3 Sensitivity — the assumptions that break the model

IF THIS IS WRONG	2028 REVENUE
Base case	\$36.1M
CMS-0057-F slips a year → payer count halves	\$34.5M
Pavo-routed share is 35%, not 50%	\$28.3M
Provider groups reach 900 average, not 1,400	\$24.4M
Auth fee compresses to \$2.00	\$27.4M
All four together	\$13.8M

The model's single greatest exposure is the provider group count, not price. Volume drives 73% of 2028 revenue.

10.4 What we are asking for, and what it buys

\$8.0M covers the \$5.58M peak burn with twelve months of buffer past EBITDA breakeven. It funds, in order of how much it de-risks the plan:

- The clinical rule library** (\$1.7M over three years). The largest COGS line and the real moat. Five rules prove a mechanism; a few thousand encoded payer criteria are a business a competitor cannot clone in a quarter.
- SOC 2 Type II and a HIPAA compliance posture** (\$520K). No payer signs without it. This is a gate, not an optimisation.
- Payer business development** (\$5.67M across three years). Slow, expensive, and the thing that makes provider acquisition cheap. We would rather over-invest here than anywhere else.
- Engineering to close the \$8.2 gaps** (\$7.46M). Live NPPES verification, the Merkle-based ZK circuit, real facility pricing via the voice agent, and the predictive classifier — in that order.

In one line

Round 1 was an argument that the human bottleneck in prior authorization is removable. Round 2 is 19,541 lines of committed code, 138 passing tests, and an 88.6 ms measured decision that says it is already removed — for the cases we have encoded. Everything from here is encoding more cases, and the financial model above is an honest account of what that costs.